

社内セキュリティ研修 | 2026年版

エンジニアのための 情報セキュリティ研修

基礎知識から、攻撃手口・開発の現場で実践するルールまで

エイトビット株式会社



目次 本日のアジェンダ

基礎の確認 → 脅威を知る → 守り方を学ぶ、の3部構成で進めます

第1部 基礎を押さえる

- なぜ今、情報セキュリティか
- 情報セキュリティとは（CIA）
- 守るべき情報 — 個人情報と機密情報
- セキュリティ事故のインパクト

第2部 脅威を知る

- 近年の脅威動向（IPA 10大脅威 2026）
- 攻撃の手口① マルウェア・ランサムウェア
- 攻撃の手口② 標的型・フィッシング
- 過去の重大な情報漏洩事例

第3部 守り方を実践する

- セキュリティの基本原則
- パスワードと認証の新常識
- エンジニアの重点対策（開発／インフラ）
- AI・メール・端末・テレワーク・物理
- 個人情報保護とコンプライアンス
- 事故対応・チェックリスト・習慣化

1 なぜ今、情報セキュリティが重要なのか

ビジネスのデジタル化とともに、サイバー攻撃は「特別な事件」から「日常のリスク」へ

あらゆる業務がソフトウェアとデータの上で動くようになりました。

その結果、たった一件の情報漏洩や一台の感染が、サービス停止・顧客離れ・多額の賠償といった経営レベルの問題に直結するようになっています。

攻撃側も大きく変わりました。

かつては腕試しや愉快犯が中心でしたが、今日では金銭目的の「ビジネス」として分業・組織化されています。攻撃ツールやランサムウェアはサービスとして売買され、専門知識がなくても攻撃できる時代になりました。

だからこそ、守るのは情報システム部門だけの仕事ではありません。

メール1通、パスワード1つ、コード1行の判断が、会社全体の安全を左右します。一人ひとりが「自分も守りの一部」だと理解することが、最も効果的な対策です。



デジタル依存の拡大

クラウド・リモート化で「守る入口」が増え続けている



攻撃のビジネス化

攻撃が分業・サービス化し、誰でも標的になり得る



一人の影響が大きい

現場の小さな油断が、組織全体の重大事故につながる

2

情報セキュリティとは

情報資産（データ・PC・サーバ・ソフトウェア・サービス）を安全に守ること



機密性

Confidentiality

許可された人だけが情報にアクセスできる状態を保つ



完全性

Integrity

情報が正確で、改ざん・欠損なく完全に保たれている



可用性

Availability

必要なときに、いつでも情報を利用できる

+ 近年はこの3要素に次の観点も加えて考えます

真正性 なりすましでなく本人・本物であること

責任追跡性 誰が何をしたか記録・追跡できること

否認防止 行為を後から否定できないこと



ISMS とは

情報セキュリティマネジメントシステム。リスクを評価し、必要な対策を計画・運用・改善し続ける組織的な仕組み（PDCA）。

3 守るべき情報 — 個人情報と機密情報



機密情報

会社経営上、重要で機密を保つ必要がある情報。一般に 極秘 / 部外秘 / 社外秘 などに区分される。

- 設計書・仕様書・議事録
- ソースコード・認証情報
- 事業計画・契約・価格情報



個人情報

機密情報のうち、氏名・住所・顔写真など、特定の個人を識別できる情報。

- 氏名・住所・電話番号
- メールアドレス・ID
- 顧客・従業員のデータ



お客様先で業務上知り得た情報も、すべて守るべき対象です。 ソースコードや認証情報・顧客データも「機密情報」だという意識を常に持ちましょう。

4

セキュリティ事故が招くインパクト

たった一つの事故が、会社・お客様・社会へ深刻な被害を広げます

セキュリティ事故

情報の漏洩・流出

ランサムウェア感染

不正アクセス

システム停止

データの改ざん



社会的信用の失墜

お客様・取引先からの信頼を一瞬で失う

損害賠償・取引停止

契約解除や多額の賠償につながる

懲戒処分

当事者個人の責任も問われる

業務停止・コスト増

復旧対応で本来の業務が止まる

結果として、業績の悪化を招く

5 近年の脅威動向 — IPA 情報セキュリティ10大脅威 2026 [組織]

攻撃は年々巧妙化。エンジニアが関わる領域が脅威の中心になっています

- 1 ランサム攻撃による被害
- 2 サプライチェーン・委託先を狙った攻撃
- 3 AIの利用をめぐるサイバーリスク（初選出）
- 4 システムの脆弱性を悪用した攻撃
- 5 機密情報を狙った標的型攻撃
- 6 内部不正による情報漏えい 等



エンジニアが効く領域

- 脆弱性対応・パッチ適用
- 依存パッケージ／委託先の管理
- AI生成物の検証・情報入力 of 管理
- 認証情報・アクセス権の適切な管理

出典：IPA「情報セキュリティ10大脅威 2026」組織編（2026年1月公表）

攻撃の手口① — マルウェアとランサムウェア

「マルウェア」は悪意あるソフトの総称。中でもランサムウェアの被害が深刻です



マルウェアの主な種類

- **ウイルス／ワーム** 他のファイルや機器に自己増殖して感染を広げる
- **トロイの木馬** 正規ソフトを装って侵入し、裏で悪意ある動作をする
- **スパイウェア／キーロガー** 入力やデータをこっそり盗み外部へ送信する
- **ランサムウェア** データを暗号化し、復旧と引き換えに身代金を要求
- **ボット** 端末を乗っ取り、攻撃の踏み台や遠隔操作に悪用する

ランサムウェア：二重恐喝の手口

- 1 侵入（脆弱性・フィッシング・VPN経由）
- 2 データを窃取してから暗号化
- 3 「復旧」と「暴露しないこと」の二重で要求
- 4 支払っても復旧の保証はなく被害が拡大

基本の防御

- OS・ソフト・機器を最新に保ち、脆弱性を塞ぐ
- バックアップを取り、復旧できる状態にしておく
- 不審なメール・添付を開かない／MFAを有効化

7 攻撃の手口② — 標的型攻撃と「人」を狙う攻撃

技術ではなく“人の心理”を突く攻撃が増加。最後の砦は一人ひとりの判断です



標的型攻撃の流れ

STEP
1

偵察 狙う組織や担当者をSNS等から調べる

STEP
2

侵入 業務を装ったメールやリンクで入口を開く

STEP
3

内部活動 権限を奪い、社内を横移動して探索する

STEP
4

目的遂行 機密を持ち出す・暗号化する・破壊する



ソーシャルエンジニアリング

- 上司や取引先になりすまして送金・情報を要求（BEC）
- 「至急」「秘密で」と急かし冷静な判断を奪う
- 電話・肩越しの覗き見・なりすまし来訪で聞き出す

怪しいと感じたら

- リンクや送信元アドレスを開く前に確認する
- 送金・認証要求は、必ず別の経路で本人確認
- 自己判断で処理せず、上長や担当へ相談・報告

8

過去の重大な情報漏洩事例から学ぶ

原因の多くは「特別な攻撃」ではなく、設定ミス・標的型メール・内部不正です

事案	規模	主な原因	教訓
大手旅行会社	約793万人分	取引先を装った標的型メールによる感染	一通のメールが大規模感染の入口になる
公的年金機関	約125万件	サイバー攻撃（標的型メール）	公共機関も例外なく狙われる
通信教育大手	約3,504万件	委託先担当者による名簿業者への売却	内部不正・委託先管理も重大リスク
ファイル転送サービス	約480万件	不正アクセス・サーバ侵入	パスワード等の使い回しに注意

共通点 高度な技術より、メール・設定・人の油断が突かれている。だからこそ日々の基本行動が効きます。

9

セキュリティの基本原則

個別の対策の土台になる、覚えておきたい考え方



多層防御

一つの対策が破られても次で守れるよう、入口・内部・出口に複数の防御を重ねる。「これだけやれば安全」は存在しない。



最小権限

各人・各システムに、業務に必要な最小限の権限だけを与える。万一侵入されても被害範囲を小さく抑えられる。



ゼロトラスト

「社内だから安全」と信頼せず、アクセスのたびに本人と端末を検証する。リモート時代の前提となる考え方。

+ 日常で意識したい3つの習慣



クリーンデスク

離席時は施錠・画面ロック、机に機密を放置しない



Need to Know

知る必要のある人にだけ情報を共有する



記録を残す

誰が何にアクセスしたかを追跡できるようにする

10 パスワードと認証の新常識

「複雑な文字を90日ごとに変更」は、もう最適解ではありません



これまでの常識（見直し対象）

- 記号・数字・大文字を必ず混ぜる複雑性ルール
- 90日ごとなど、定期的な強制変更
- 短くてもルールを満たせばOKという発想



いまの推奨（NIST SP 800-63B ほか）

- 複雑さより「長さ」。覚えやすい長いパスフレーズ
- 定期変更は不要。漏洩が疑われた時に変更する
- 使い回さず、パスワード管理ツールで保管する



パスワードに依存しない — 多要素認証（MFA）とパスキー

認証の3要素 ①知識（パスワード） ②所持（スマホ・トークン） ③生体（指紋・顔）。複数を組み合わせるのがMFA。

パスキー（FIDO2） パスワード自体をなくし、端末の生体認証で安全にログインする新しい方式。フィッシングに強い。

11 エンジニアの重点対策① 開発・コード

日々のコーディングが、そのままセキュリティの最前線です



シークレットを書かない

- APIキー・パスワード・トークンをコードや設定に直書きしない
- Secrets Manager・Vault・環境変数で管理
- 誤コミット時は履歴を無効化し、鍵を即ローテーション



リポジトリ管理

- 原則 private リポジトリで管理する
- 公開前に機密情報の混入をスキャン
- .env や鍵ファイルは .gitignore で除外



依存・サプライチェーン

- 信頼できる提供元のパッケージのみ利用
- 脆弱性スキャン（SCA / Dependabot 等）を有効化
- ロックファイルで固定し、定期的に更新



セキュアコーディング

- 入力値の検証と出力のエスケープを徹底
- OWASP Top 10（SQLi・XSS 等）を意識
- AIが生成したコードも必ずレビューする

12 エンジニアの重点対策② インフラ・アカウント

権限とアクセスの管理ミスが、大規模な漏洩につながります



最小権限の原則

- 業務に必要な権限だけを付与する
- 共有アカウントを避け、個人単位で管理
- 不要権限・退職者アカウントは速やかに削除



多要素認証（MFA）

- クラウド・VPN・管理コンソールはMFA必須
- SSH鍵・トークンは安全に保管し定期更新
- 推測されにくい長いパスフレーズを使う



本番データの取り扱い

- 個人情報・機密データを開発環境にコピーしない
- 必要時はマスキング／ダミーデータを使う
- アクセスはログを残し追跡可能にする



クラウドの設定

- 公開バケット・全開放の通信設定に注意
- IaCと構成チェックで設定ミスを防ぐ
- ログ・監視・アラートを有効化する

13 AIの利用とセキュリティ

生成AIは強力な道具ですが、使い方を誤ると情報漏洩や品質事故につながります



入力からの情報漏洩

- 社外秘・個人情報・ソースコードを安易に入力しない
- 会社が許可していないAIサービス（シャドーAI）を使わない
- 入力内容が学習や外部に渡る可能性を意識する



生成物の鵜呑み

- 事実誤り（ハルシネーション）を必ず人が検証する
- 生成コードの脆弱性・ライセンスを確認する
- 他者の権利を侵害していないか確認する



安全にAIを使う3つのルール

1

許可されたツールを使う

会社が承認したサービス・利用範囲を守る

2

機密は入れない

社外秘・個人情報・認証情報は入力しない

3

出力は必ず検証

事実・コード・権利を人の目で確認してから使う

14 メール誤送信・フィッシング対策

うっかりの誤送信も、巧妙な攻撃メールも、どちらも大きな事故の入口です



誤送信を防ぐ

- 宛先はアドレス帳から選び、会社名＋フルネームで確認
- 「全員に返信」「転送」は送信前に宛先を再確認
- 機密情報は本文に書かず、共有ストレージのリンクで
- 送信前に一呼吸。送信遅延（数分保留）設定を活用



フィッシング・標的型を見破る

- 差出人アドレス・ドメインの微妙な違いに注意
- 不審なリンク・添付は開かない（URLは事前に確認）
- 心当たりのない送金・認証要求は別経路で確認（BEC対策）
- 少しでも怪しければ、自己判断せず必ず報告

15 デバイス・アカウント管理

PCとアカウントは、自分が守る最初の砦です



端末の基本

- OS・ソフトは常に最新に（自動更新を有効化）
- ウイルス対策ソフトを稼働・定義を最新に
- 離席時は必ず画面ロック
- ディスクは暗号化しておく



アカウント・認証

- 長く強いパスフレーズを使い、使い回さない
- パスワードマネージャで管理する
- 重要サービスは多要素認証（MFA）を有効化



やってはいけない

- 私物USB・私物端末の業務利用（原則禁止）
- 許可されていないソフトの導入
- 業務外サイトの閲覧・書き込み
- 公共PC・無料Wi-Fiでの機密作業



【ブラウザの更新ポイント】

最新版の Edge / Chrome / Firefox / Safari を使用し、自動更新を有効に。**サポート終了済みの Internet Explorer は使用しない。**指定外のブラウザを使う場合はシステム担当に事前相談する。

16 テレワーク・社外作業のセキュリティ

オフィスの外でも、社内と同じ意識で。場所が変わってもルールは変わりません



通信を守る

- 公共の無料Wi-Fiでは機密作業をしない
- 社内システムへは会社指定のVPN等で接続
- 通信は暗号化（HTTPS）を確認する



のぞき見・盗難を防ぐ

- カフェ・電車では覗き見に注意（防止フィルム）
- 離席時は端末を放置せず必ずロック
- 端末・書類の車内放置や置き忘れに注意



端末と環境

- 会社が許可した端末・環境で作業する
- 家族や同居人と端末・アカウントを共有しない
- Web会議は背景の機密情報の写り込みに注意



データの扱い

- 個人クラウドや私物USBに業務データを保存しない
- 必要なデータは会社の共有ストレージで扱う
- 作業後は不要なローカルデータを残さない

17 物理セキュリティ — ID・入館証の取り扱い

貸与品の社員証・入館証は、貴重品と同じく厳重に管理します



取り扱いの基本ルール

- 社員証・入館証は最後に提示したその場でしまう。移動時はストラップで身体や鞆に固定する
- 鞆に入れる場合は立ち止まって確認し、チャック付きポケットへ。電車の網棚には乗せない
- 飲酒時の事故が多発。飲む際は携帯を避ける／休日など不要時は持ち歩かない
- ケースやストラップの劣化はすぐに交換する
- 引越し時の紛失も多い。貴重品と同様に厳重管理する



**紛失したら
「探す前に報告」**

警察・交通機関へ届出、機能
停止の手続きを速やかに行う

18 個人情報保護とコンプライアンス

セキュリティはルールやマナーであると同時に、守るべき「法令」でもあります



個人情報保護法のポイント

- 利用目的を明確にし、その範囲内で利用する
- 漏えい・滅失を防ぐ安全管理措置を講じる
- 本人同意なく第三者へ提供しない
- 漏えい時は本人通知・委員会報告が義務化



守るべき約束・権利

- 秘密保持契約（NDA）・就業規則を遵守する
- ソフトウェアのライセンス・利用規約を守る
- 著作権・他者の知的財産を侵害しない



違反は会社だけでなく個人の責任にも。
ら、勝手に進めず必ず確認しましょう。

ルールは「面倒な制約」ではなく、自分と会社、そしてお客様を守るためのもの。判断に迷った

19 事故発生時の対応

対応スピードが、お客様からの信頼に直結します

検知・気づく

>

すぐ報告

>

初動対応

>

復旧

>

再発防止



すぐに報告 → みんなで対応

- 緊急連絡先に基づき、まず上長へ報告
- 時間外・休日・深夜でも直ちに連絡する
- 事実を正確に、隠さず共有する



一人で対応・探す・隠す

- 報告が遅れ、被害が拡大する
- 隠ぺいは、より重大な問題に発展する
- 個人で抱え込まず、必ずチームで対応



迷ったら、まず報告。早い報告ほど、信頼を守る。

20 セキュリティルール チェックリスト

日々の業務で「必ず」守る基本ルールのまとめ

基本姿勢

- ✓ 自社・お客様先のセキュリティポリシーを理解し遵守する
- ✓ 業務上知り得た情報をSNS等には書き込まない／社外で話さない

保管・廃棄

- ✓ 機密情報は施錠・アクセス制御で保管し、業務PCや個人クラウドに残さない
- ✓ 書類はシュレッダー/溶解、媒体は物理破壊。退職・PJ終了時は全て返却

送信・授受

- ✓ 個人・機密情報の送信は宛先と内容を複数人で確認する
- ✓ 情報の授受は共有ストレージ経由、メール添付は避ける

持ち出し・接続

- ✓ 持ち出しは承認＋管理簿で記録し、暗号化する
- ✓ 個人端末からの社内/客先システム接続は原則禁止（M365は閲覧のみ等を遵守）

21 セキュリティを「習慣」に

高度な技術より、毎日の小さな行動の積み重ねが組織を守ります



アップデートを後回しにしない

更新通知が来たら早めに適用する



離席時は必ずロック

数十秒の離席でも画面ロックを徹底



送信前に宛先を確認

「全員返信」「添付」は指差し確認



怪しいメールは開かず報告

判断に迷ったら自分で処理しない



パスワードは使い回さない

管理ツール+MFAで守る



おかしいと思ったら即共有

早い報告が被害を最小化する

セキュリティは特別なことではなく、日々の仕事の一部。 一人ひとりの当たり前が、会社とお客様の信頼を守ります。

MESSAGE

**お客様先では、必ずルールに従って
情報セキュリティを守りましょう。**

お客様の信頼を維持・向上させるのは、わたしたち一人ひとりの行動です。

よろしくお願いいたします。

